Alula Finance Audit v2

October 2026



Disclaimer **2**
About Highland Security **3**
Executive Summary **4**
Engagement Summary 4
Post Incident Fix Validation 4
Background and scope 5
Approach 5
Findings Overview 6
Technical Information **6**
Overview 6
Soroban Security Assessment 7

Disclaimer

This report does not constitute legal or investment advice. You understand and agree that this report relates to new and emerging technologies and that there are significant risks inherent in using such technologies that cannot be completely protected against. While this report has been prepared based on data and information that has been provided by you there are likely additional unknown risks which otherwise exist. This report is also not comprehensive in scope, excluding a number of processes critical to the correct operation of this system and subsequent changes could have unintended consequences to the product's security. It is important to note that, although we did our best in our analysis, no code audit or assessment is a guarantee of the absence of flaws. Our effort was constrained by resource and time limits along with the scope of the agreement. This report is for informational purposes only and is provided on an "as-is" basis and you acknowledge and agree that you are making use of this report and the information contained herein at your own risk. The preparers of this report make no representations or warranties of any kind, either express or implied, regarding the information in or the use of this report and shall not be liable to you or any third parties for any acts or omissions undertaken by you or any third parties based on the information contained herein. Finally, the possibility of human error in the manual review process is very real, and we recommend seeking multiple independent opinions on any claims.

About Highland Security

Highland Security is a leading security company providing consulting services with more than a decade of security expertise. We are experts in AI product security, web application security, security automation, and risk management. We offer our clients tailored AI security services that can provide value at any stage of maturity or product development lifecycle.

Our goal is to establish a long lasting security partnership for our clients that continues beyond the engagement. We consider the unique business needs and situations of our clients on a case-by-case basis and adapt our approach to provide the best value. Contact us at our website or hello@highlandsecurity.io to schedule a free consultation with our team today. To keep up with our latest endeavors and research follow us on X @0xHighlandSec.

Executive Summary

Engagement Summary

Alula Finance engaged Highland Security in October 2026 to perform a re-test of the protocol after an incident was detected in production. The protocol was paused and fixes implemented by the Alula team, that were then reviewed by Highland Security. In addition to testing the specific fixes, we re reviewed the entire protocol, including flash-batch accounting and pricing. All findings identified during the reassessment have been remediated in the reviewed codebase. No Critical or High vulnerabilities were identified. Based on the assessment, Highland Security considers the protocol suitable for relaunch, subject to deployment of the assessed code and no further material, unreviewed changes.

The following table summarizes the results of this assessment:

Workstream	**Critical**	**High**	**Medium**	**Low**	**Info**
Soroban Security Assessment	-	0	2	7	0
Fixed	-	-	2	7	-

Post Incident Fix Validation

Highland Security reviewed the incident report provided by Alula Finance against our audit records and current code base. The accounting interaction that enabled the exploit was the flash borrow removed the borrowed amount from the pool's accounting instead of reserving it. A deposit into the same pool, in the same batch, therefore saw a nearly empty pool and minted supply shares at a collapsed price. The attacker redeemed those shares in a later transaction draining the pool. Highland Security reviewed the complete PR, with particular attention to batch composition and accounting invariants as well as re auditing the protocol including any changes that were made after the original audit specifically for this vulnerability variant and were not able to reproduce this type of attack with the fixes implemented.

Background and scope

In October 2026 Highland Security performed a penetration test of Alula Finance's lending protocols' Soroban smart contract. The goal of the assessment was to retest the Alula Finance products after fixes for a recent incident had been applied. Highland Security performed a full re audit of the protocol, including flash-batch share pricing and batch accounting flows This engagement was conducted from October 3rd - 18th and included interviews with Alula Finance's personnel on their expected product operations and architecture, manual review of source code, dynamic testing of the product's programs and contracts Specifically we performed the following:

Name	Description	Scope
Soroban Security Assessment	A security assessment of the alula lending protocol to identify vulnerabilities and provide recommendations to address the risk	• pointgroup-labs/alula • Branch: Fix: dev • Commit: dc904816187547f4d491f55b598c4641365ec4d0

Approach

The following was our approach to execute this engagement:

- *Kick off & planning* - During this phase the team worked with project sponsors to identify key stakeholders for the assessment. Documentation and access to source code and environments was also provisioned as part of this phase. We also performed interviews with key stakeholders to understand how the product works, key product features, and the team's approach to security.

- *Fieldwork* - Once the relevant details for the engagement was collected the fieldwork fieldwork activities started with a documentation, source code, and environment review to familiarize the team with the product functionality and create an efficient assessment approach. We then performed manual and dynamic testing of the in scope components to identify vulnerabilities and security misconfigurations.

- *Reporting & verbal briefings* - After the fieldwork was completed, the Highland Security team compiled the information gathered into a draft report document and reviewed the output with project stakeholders. This was an iterative process with feedback from the team being incorporated into a final deliverable.

Findings Overview

- *Reliable Market Pricing:* The review identified weaknesses in how price updates are validated over time, although the current production system is not exposed to the AMM manipulation scenario. An attacker would still need significant influence over the active oracle sources. Use fixed comparison points, protocol-recorded timestamps, and sufficiently independent price providers.
- *Fair Farm Rewards:* The farming system is not currently enabled in production, but activating it could expose stale reward balances and allow users to gain disproportionate rewards through many small positions. These issues could dilute legitimate participants or misallocate incentives. Clear farm balances when positions close, enforce meaningful minimum stakes, and calculate rewards at the owner level.
- *Resilient Protocol Operations:* Several arithmetic and payment-handling conditions could interrupt farming or fee distribution under unusual configurations. These issues are currently dormant or recoverable but could delay access to rewards or protocol fees. Use higher-capacity arithmetic, enforce configuration limits, add emergency recovery controls, and isolate failed fee payments.

Technical Information

Overview

The below risk ratings were mutually agreed upon for use between Alula Finance and Highland Security at the start of this assessment:

Composite Risk Rating		
Rating	*Description*	*Count*
Critical	The identified exposure would lead to immediate loss of assets and have significant business impact. The issue is directly exploitable with little complexity and causes an immediate impact to the confidentiality, integrity, or availability of the system.	0

High	The identified exposure could lead to a loss of assets and have a business impact. The identified issues may be directly exploitable and would impact the confidentiality, integrity, or availability of the system for one or many users	0
Medium	The identified exposure is not directly exploitable but combined with other issues it may allow for exploitation of the system. The identified issue would impact the confidentiality, integrity, or availability of the system for a singular user.	2
Low	The identified exposure is not directly exploitable but unnecessarily increases the attack surface of the system. The identified issue does not directly impact the confidentiality, integrity, or availability of the system but could be used with additional findings to increase the likelihood of success.	7

The following table summarizes the results of this assessment:

Workstream	**Critical**	**High**	**Medium**	**Low**	**Info**
Soroban Security Assessment	0	0	2	7	0
Fixed	-	-	2	7	-

Soroban Security Assessment

Bad-Debt Settlement Leaves Permanent Phantom Farm Stakes
Bad-debt settlement removes supply and debt positions without updating their delegated stakes in the Farms contract. The farm therefore continues treating removed j-token or d-token balances as active. **Preconditions:** The affected pool has a supply or debt farm, and bad-debt settlement removes a position tracked by that farm.
Affected Location
contracts/market/src/processors.rs:885; contracts/market/src/processors.rs:914; contracts/market/src/farms.rs:81

Risk Rating
Medium
Impact
Defaulted borrowers and removed depositors can continue earning rewards against nonexistent positions, diluting legitimate participants. **Exploit Scenario:** A borrower defaults while participating in a debt farm. Settlement writes off the debt and removes the Market position but never sends a zero stake to Farms. The former borrower continues harvesting rewards against the stale balance.
Status: Fixed
Recommendation
Push each position's post-settlement stake, including zero, before removing it. Extend the repair entry point so removed obligations and pools can still be explicitly synchronized.
Management Response
Bad-debt cover zeroes every settled stake in the same tx; refresh_farm_stakes resyncs removed obligations.

Seeded Obligations Enable Sybil Capture of Constant Farm Rewards
Description: Delegated farms count each unique owner and seed pair as a separate user without enforcing min_stake_amount. Under RewardType::Constant, every seeded obligation receives the same reward weight. **Preconditions:** A Market-attached farm uses Constant rewards, the pool has no meaningful minimum deposit, and dust deposits mint nonzero j-token balances for multiple seeds.
Affected Location
contracts/farms/src/processors.rs:276; contracts/market/src/obligation.rs:36
Risk Rating

Medium
Impact
An attacker can capture most farm emissions and materially dilute honest participants. **Exploit Scenario:** One account creates hundreds of obligations with different seeds and deposits a few base units into each. Each obligation increments num_users, allowing the attacker to capture nearly all Constant emissions while providing negligible liquidity.
Status: Fixed
Recommendation
Apply min_stake_amount to delegated stakes and exclude sub-minimum positions from num_users and Constant reward calculations.
Management Response
Constant rewards are refused; Proportional rewards are stake-weighted, so splitting gains nothing.

Public Price Reads Can Ratchet the Deviation Baseline
Every successful public lastprice call replaces the baseline used by the deviation circuit breaker. The control therefore limits movement per retrieval instead of cumulative movement during the configured window. **Preconditions:** The attacker can influence a source enough to move the median, the source is decisive, and each individual change remains within max_dev_bps.
Affected Location
contracts/aggregated-oracle/src/contract.rs:215; contracts/aggregated-oracle/src/contract.rs:232
Risk Rating

Low

Impact

An attacker can inflate collateral values, suppress prices to trigger liquidations, or weaponize the breaker to prevent liquidation.

Exploit Scenario: An attacker moves the median by 4.9% where the limit is 5%, calls lastprice to store the new baseline, and repeats. Each step passes while the cumulative accepted price moves far from the original value.

Status: Fixed

Recommendation

Keep a fixed anchor for each deviation window and limit cumulative movement against it, or compare against a TWAP or EMA that arbitrary callers cannot advance.

Management Response

Each deviation window keeps a fixed anchor

Rewards-Per-Share Arithmetic Can Permanently Reject Large Stakes

Farm accounting multiplies a user's stake by the scaled accumulated rewards per share using i128 arithmetic. The intermediate multiplication can overflow even when the final divided value would fit.

Preconditions: The farm has a zero or small minimum stake, and rewards accrue while a dust position represents most or all of total_staked. The fund-locking variant also requires a non-delegated farm with a warm-up period.

Affected Location

contracts/farms/src/processors.rs:382; contracts/farms/src/state.rs:149

Risk Rating

Low

Impact

Users can be permanently prevented from staking, pending deposits can become trapped, and large delegated positions can silently stop receiving rewards.
Exploit Scenario: An attacker stakes one base unit while rewards accrue. The rewards-per-share accumulator becomes large enough that a later normal-sized stake overflows when its tally is calculated. A warm-up deposit may transfer successfully and then become impossible to activate or withdraw.

Status: Fixed

Recommendation

Use I256 or environment-aware fixed-point arithmetic for scaled multiplication and division. Enforce a meaningful minimum stake and provide a direct withdrawal path for pending deposits.

Management Response

Widened arithmetic, no dust unstakes, pending deposits can be withdrawn.

Unbounded Reward Rate Can Permanently Brick a Farm

The reward schedule accepts any non-negative reward_per_time_unit. A sufficiently large value overflows when multiplied by elapsed time, and every operation that calls refresh_rewards then reverts.

Preconditions: A farm admin configures an excessive rate, the farm has active stakers, and enough time elapses for the rate multiplied by the duration to exceed i128.

Affected Location

contracts/farms/src/math/reward_curve.rs:73

Risk Rating

Low

Impact

Active stakes and unclaimed rewards can remain frozen until the contract is upgraded.

Exploit Scenario: A farm admin installs i128::MAX as the reward rate. On the next ledger, reward calculation overflows. Stake, unstake, harvest, reward withdrawal, and schedule replacement all fail because each path first refreshes rewards.

Status: Fixed

Recommendation

Bound reward_per_time_unit, validate its maximum integral, use widened or saturating arithmetic, and provide an emergency schedule-replacement path that does not refresh the invalid schedule first.

Management Response

Issuance is capped by the funded budget, totals saturate, the schedule stays replaceable.

Deviation Window Uses Source Timestamp Instead of Previous Call Time

The deviation window uses the timestamp embedded in the previously accepted median. For periodic sources, that value is the source signing time rather than the ledger time at which the price was accepted.

Preconditions: A periodic source contributes to the median, its signing timestamp is materially old, and the configured deviation window is comparable to that data age.

Affected Location

contracts/aggregated-oracle/src/contract.rs:213;
contracts/aggregated-oracle/src/computations.rs:42

Risk Rating

Low

Impact

Large manipulated price changes can be accepted before the configured window has elapsed.

Exploit Scenario: A price accepted at time T contains a signing timestamp of T-250 and the window is 300 seconds. A call at T+60 is treated as 310 seconds later, so the deviation check is skipped despite only 60 seconds passing.

Status: Fixed

Recommendation
Store the accepting ledger timestamp separately from source timestamps and use it exclusively for deviation-window calculations.
Management Response
The window runs on the ledger time of acceptance.

Pending Farm Deposits Are Excluded From the Locking-Configuration Guard
Locking parameters can be changed whenever total_staked is zero. Deposits in warm-up and withdrawals in cooldown are not included, even though user funds are already exposed to the farm. **Preconditions:** A non-delegated farm has a warm-up period, users have pending deposits while total_staked remains zero, and the farm admin changes the configuration before activation.
Affected Location
contracts/farms/src/state.rs:230
Risk Rating
Low
Impact
A malicious farm admin can retroactively lock or confiscate pending principal through penalties. **Exploit Scenario:** Users deposit under a no-lock configuration. Before activation, the admin changes the farm to a 365-day lock with a 100% early-withdrawal penalty. Users cannot cancel the pending deposits and must activate under the new terms.
Status: Fixed
Recommendation
Include pending deposits and withdrawals in the immutability guard, snapshot terms at deposit time, and provide a user-controlled cancellation path for pending deposits.
Management Response
Terms are frozen while deposits or withdrawals are pending; past-dated locks are refused.

Scaled Reward Issuance Can Overflow and Freeze a Farm
refresh_rewards multiplies rewards_to_issue by 1e18 before dividing by total_staked. The intermediate i128 value overflows when one refresh attempts to issue approximately 1.7e20 base units or more. **Preconditions:** The token precision and emission rate make the threshold attainable, rewards_available is sufficiently large, the farm has active stakers, and the farm remains idle long enough to cross the threshold.
Affected Location
contracts/farms/src/state.rs:149
Risk Rating
Low
Impact
Active principal and rewards can remain frozen until the contract is upgraded. **Exploit Scenario:** An 18-decimal reward emits 1e16 base units per second and the farm remains idle for several hours. The next refresh overflows during scaling, after which unstake, harvest, and schedule repair all revert.
Status: Fixed
Recommendation
Use I256 intermediates, cap per-refresh issuance, and provide an emergency path that can reset issuance state without executing the failing calculation.
Management Response
Widened arithmetic, saturating totals.

Failing Fee Beneficiary Temporarily Blocks Fee Distribution and Immediate Beneficiary Updates
Fee distribution transfers directly to each beneficiary or calls InsuranceFund.add_reserves without isolating failures. Beneficiary setters distribute existing fees before saving a replacement map. **Preconditions:** A configured beneficiary or Insurance Fund becomes unable to accept payment, fees have accrued, and the admin attempts distribution or a beneficiary update.
Affected Location
contracts/market/src/processors.rs:1167; contracts/market/src/contract.rs:660
Risk Rating
Low
Impact
Fee distribution and beneficiary administration can remain unavailable, trapping protocol fees. **Exploit Scenario:** A beneficiary's trustline is removed or frozen. Distribution fails, and the admin cannot remove the broken beneficiary because the setter first retries the same failing transfer.
Status: Fixed
Recommendation
Use pull-based fee accounting or isolate failed recipient payments while retaining unpaid balances. Permit beneficiary updates without requiring a successful final distribution to every existing recipient.
Management Response
Zero amounts are skipped; the admin can replace a beneficiary that cannot receive.